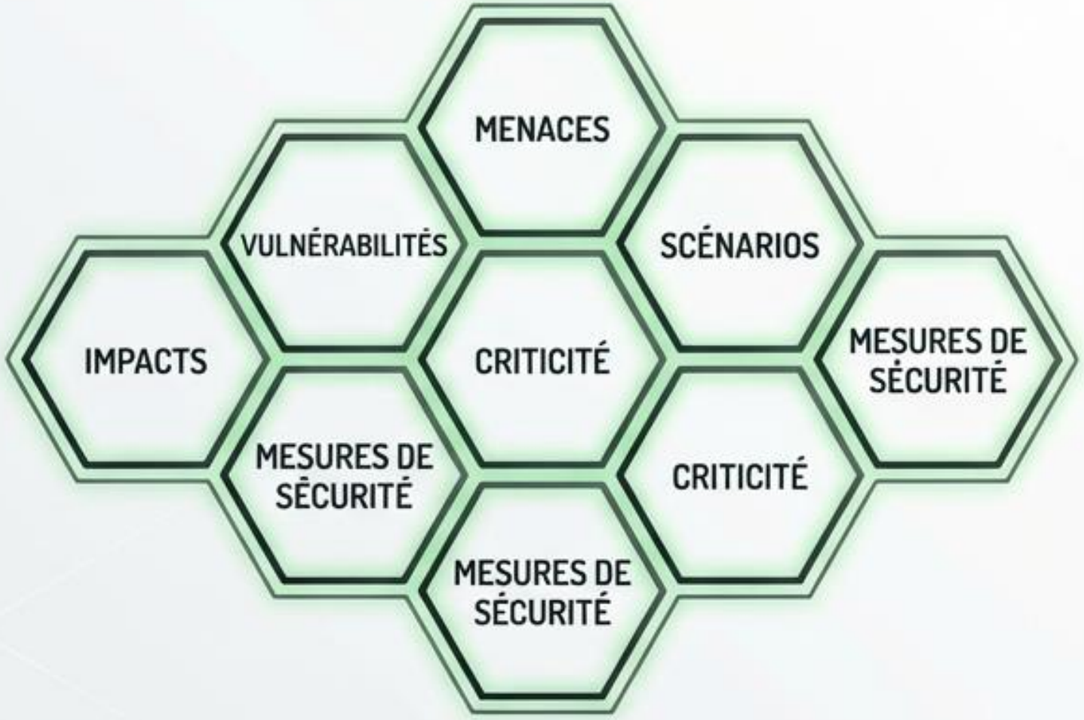
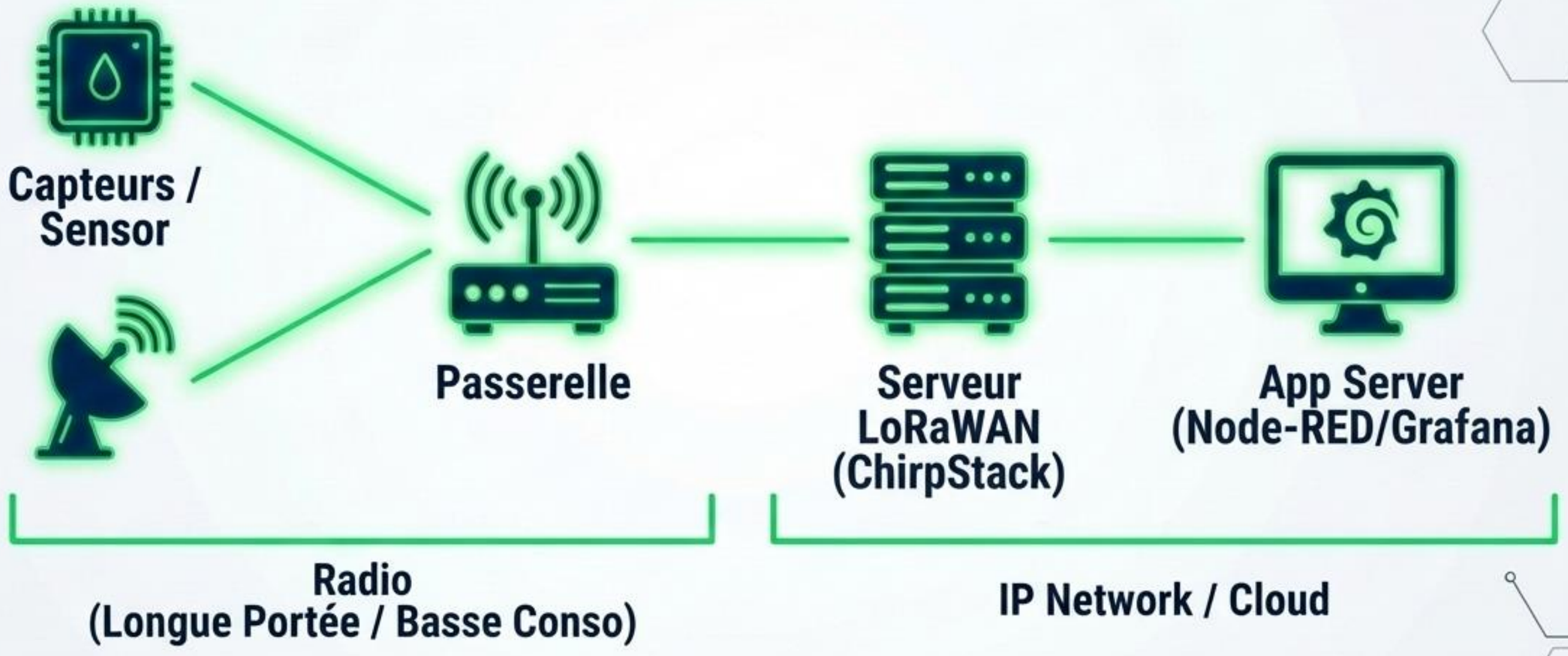


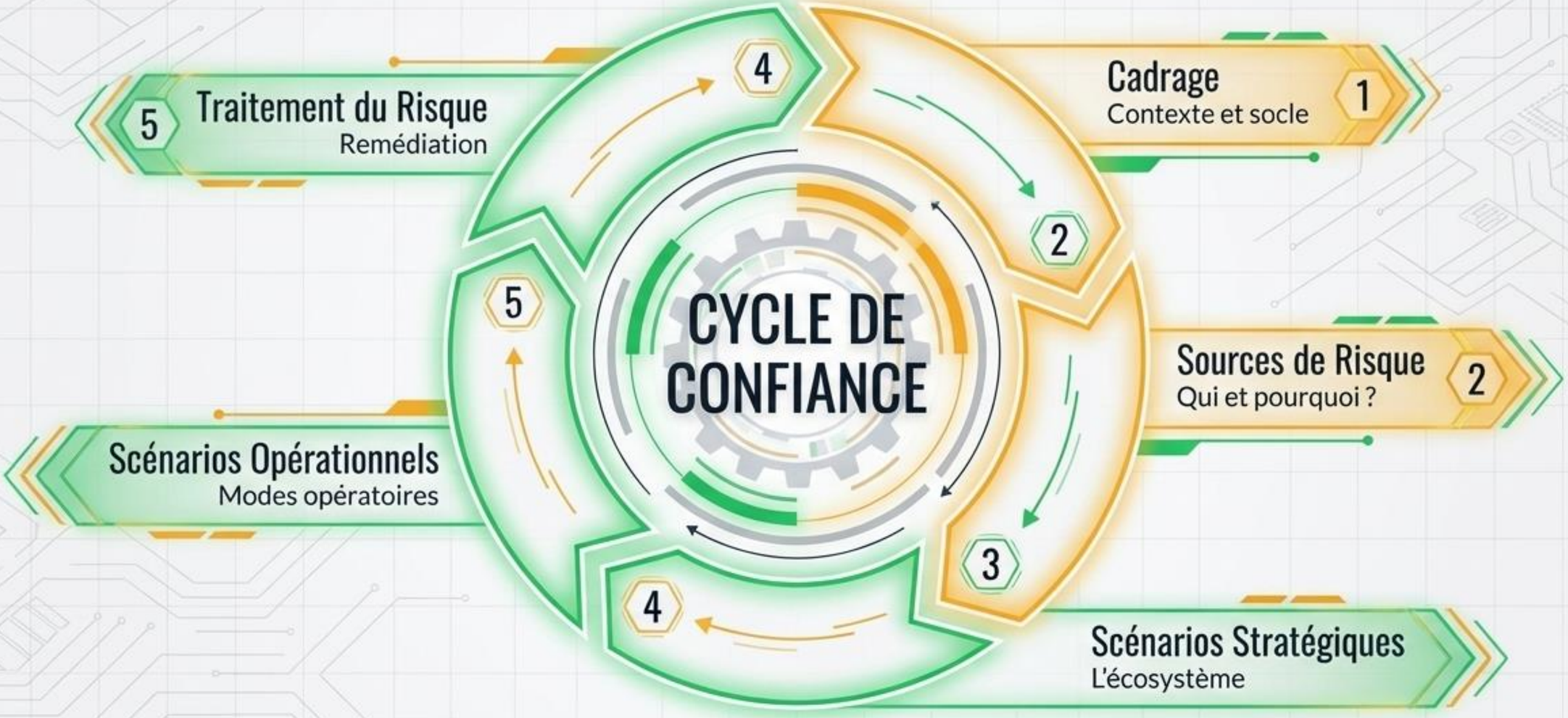
SÉCURISER L'INTERNET DES OBJETS
UNE APPROCHE LoRaWAN & EBIOS RM

Une méthodologie d'analyse de risques pour la protection des architectures IoT critiques

CARTOGRAPHIE DE LA CIBLE : ARCHITECTURE LoRaWAN



LA MÉTHODE EBIOS RISK MANAGER



De la gouvernance à la technique.

ATELIERS 1 & 2 : IDENTIFIER LA MENACE ET LES ENJEUX

VALEURS MÉTIER
(Ce qu'on protège)

- **Intégrité** : Fiabilité des relevés (Météo, Industriel)
- **Disponibilité** : Continuité du service de monitoring

SOURCES DE MENACE
(Qui attaque ?)

- **Cybercriminel** : Ransomware, Crypto-minage
- **Saboteur / Concurrent** : Brouillage radio, Falsification
- **Environnement** : Inondations, Perte solaire

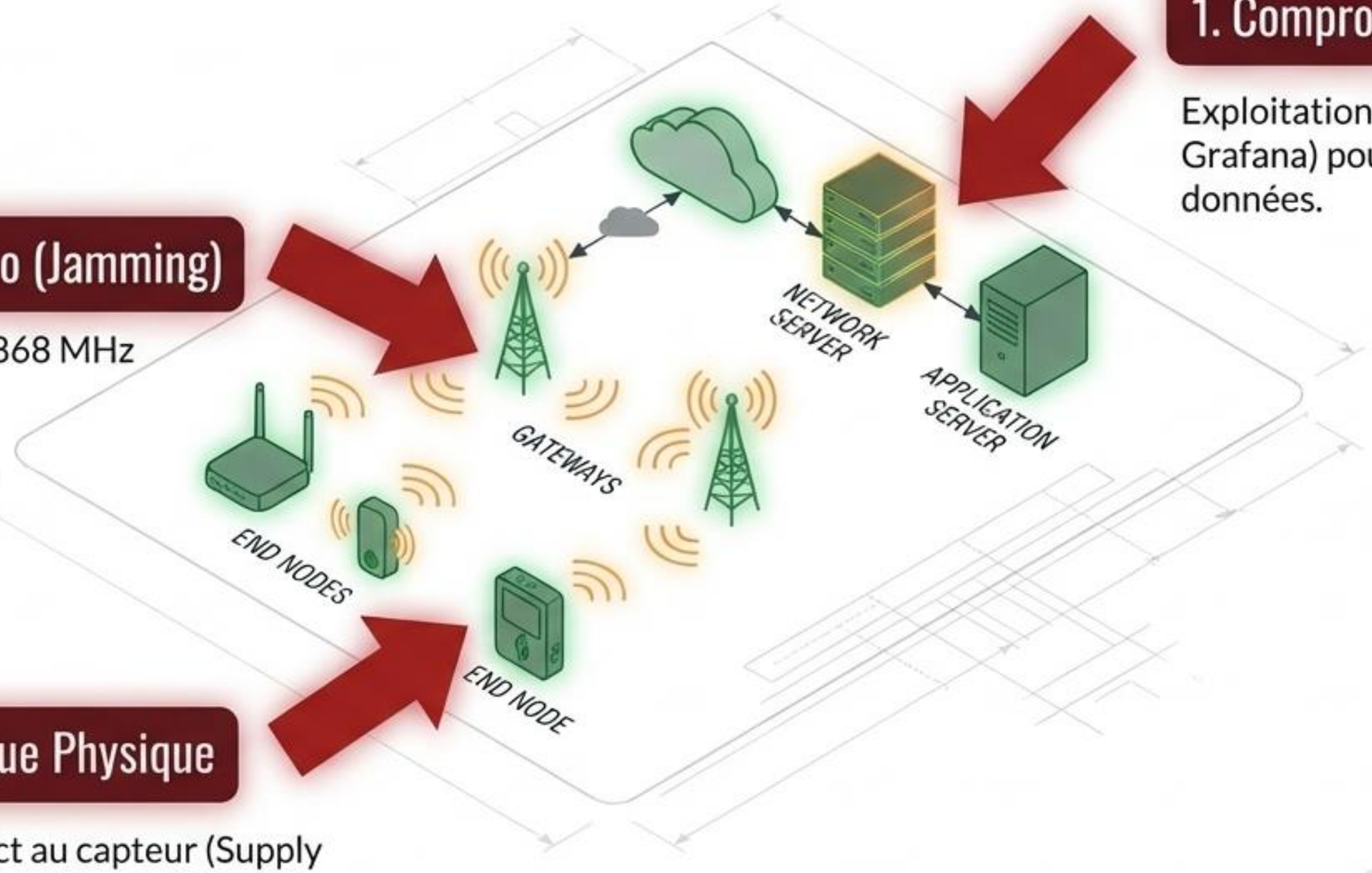
ATELIER 3 : SCÉNARIOS STRATÉGIQUES D'ATTAQUE

1. Compromission du Cloud

Exploitation Web/API (ChirpStack, Grafana) pour altérer les bases de données.

2. Interférence Radio (Jamming)

Saturation de la bande 868 MHz (Déni de Service).



3. Attaque Physique

Accès direct au capteur (Supply Chain) pour extraction de clés.

ATELIER 4 : ANATOMIE D'UNE ATTAQUE (REPLAY ATTACK)

Comment un attaquant peut-il falsifier la météo d'hier ?

SNIFFING

L'attaquant capture un paquet LoRaWAN valide.

DELAY

Attente stratégique.

REPLAY

Réémission du paquet. Le serveur accepte la fausse donnée.

Corruption de l'historique de données.

Comment un attaquant peut-il falsifier la météo um.

LE CŒUR DE LA SÉCURITÉ : CRYPTOGRAPHIE ET CLÉS

Intégrité du Réseau
(Vérifié par le MIC).
Le réseau sait *qui* parle.

Confidentialité des Données (AES128).
Seul l'applicatif comprend *ce qui* est dit.

GESTION DES CLÉS : LE CHOIX CRITIQUE (ABP vs OTAA)

ABP (Activation By Personalization)

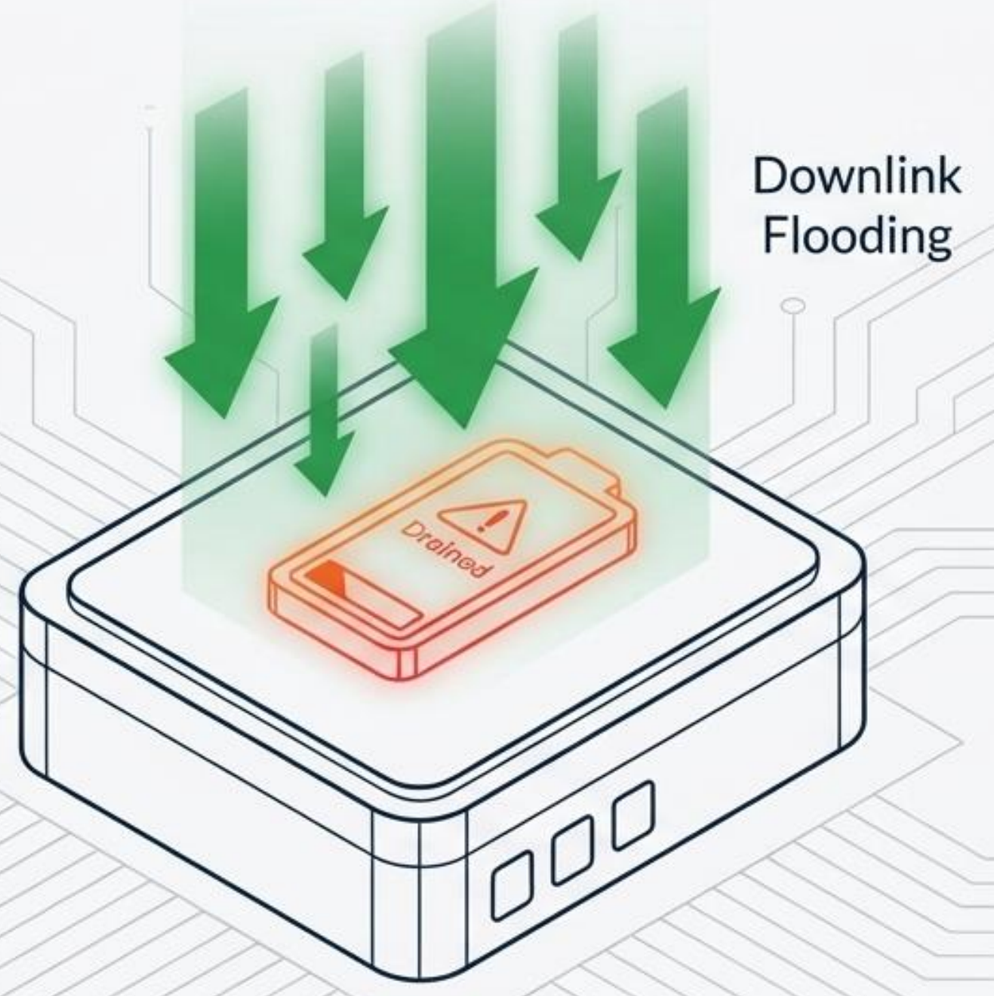
- Clés codées en dur dans le capteur.
- **RISQUE ÉLEVÉ** : Vol de clés définitif si compromission physique.
- Sensible aux Replay Attacks.

OTAA (Over-The-Air Activation)

- Négociation dynamique (Handshake).
- **SÉCURISÉ** : Clés de session régénérées à chaque connexion.

Recommandation : OTAA Impératif.

SCÉNARIO OPÉRATIONNEL : ‘DENIAL OF SLEEP’



- **Le Concept :** L’attaquant inonde le réseau de demandes.
- **L’Effet :** Le capteur ne peut jamais passer en mode ‘Sleep’.
- **L’Impact :** La batterie de 1000mAh se vide en quelques jours au lieu d’années.
- **Résultat :** Sabotage matériel et arrêt de service.

ATELIER 5 : PLAN DE TRAITEMENT ET REMÉDIATION

PROTOCOLE

Forcer l'utilisation de **OTAA** pour la rotation des clés.

INTÉGRITÉ

Vérification stricte des **Frame Counters (f_cnt)** pour bloquer les Replay Attacks.

INFRASTRUCTURE

Sécurisation **TLS/HTTPS** pour les flux MQTT et API.

Isolation de la base **InfluxDB**.

SURVEILLANCE

Détection de chutes brutales du **SNR** (Indicateur de brouillage).